API Security Recommendations & Attack Flow Analysis

Prepared by: Vimal Raj R

Date: 30/03/2026

Project: API Security Risk Analysis

Executive Summary

This document provides a comprehensive analysis of API security vulnerabilities and actionable recommendations to strengthen your system's defenses.

Current State

API endpoints lack authentication, authorization, and rate limiting controls

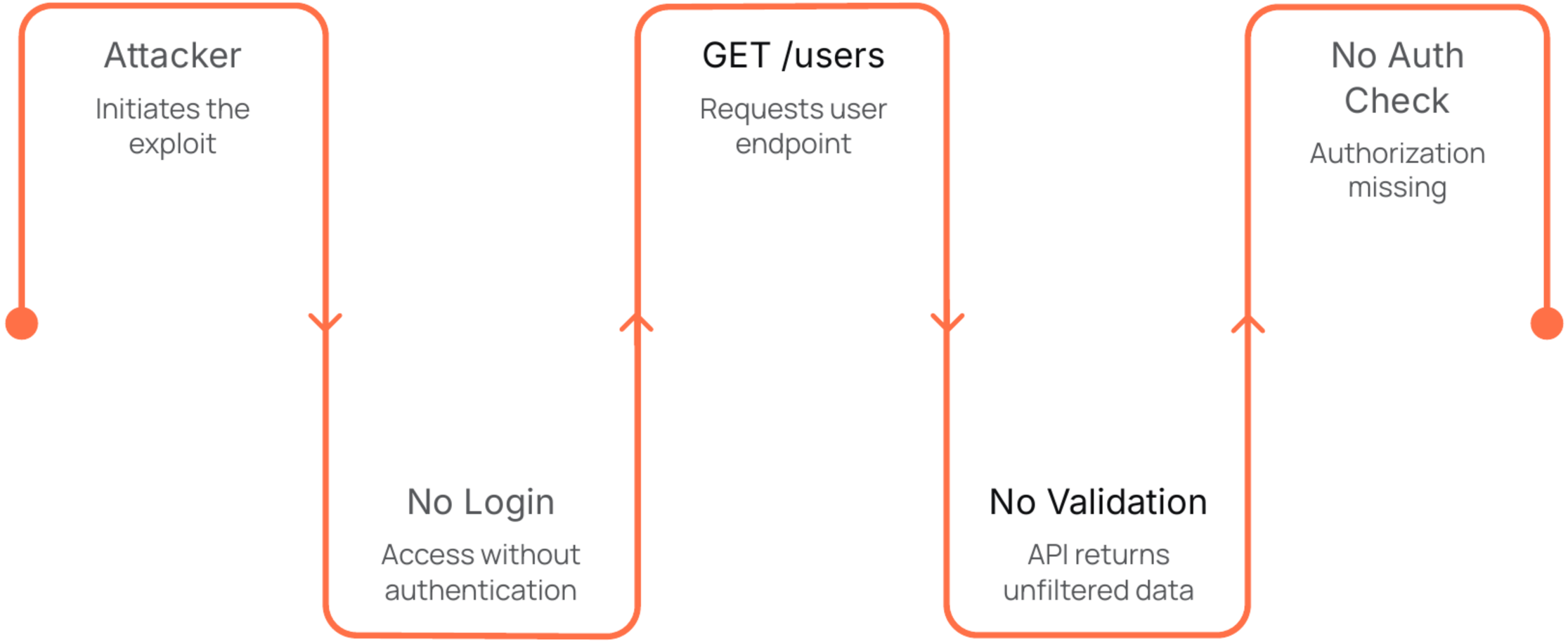
Impact

Unauthorized access to user data with potential for large-scale data exfiltration

Resolution

Implement layered security controls to protect sensitive information

Attack Flow: How Vulnerabilities Are Exploited



Phase 1: Initial Access

1

Discovery

Attacker identifies API endpoints that don't require authentication

2

Testing

Sends simple GET requests to verify data accessibility

3

Confirmation

Receives complete user data without credentials

The absence of authentication creates an open door. Any individual can access sensitive user information by simply sending HTTP requests to exposed endpoints.

Phase 2: Data Extraction

No Access Control

API doesn't verify user permissions or request origin. Each request returns full user profiles regardless of who's asking.

Unlimited Requests

No rate limiting allows attackers to send thousands of requests per second, rapidly collecting massive datasets.

Complete Exposure

All user records accessible through sequential endpoint calls like /users/1, /users/2, /users/3

Phase 3: Data Misuse

Account Takeover

Stolen credentials used to hijack legitimate user accounts

Identity Theft

Personal information exploited for fraudulent activities

Reputation Damage

Loss of user trust and regulatory compliance violations

Security Recommendations

01

Implement Authentication

Require valid credentials (API keys, OAuth tokens) before processing any request

02

Enforce Authorization

Verify user permissions before returning data—users should access only their own information

03

Apply Rate Limiting

Restrict requests per user/IP address to prevent automated data scraping

04

Reduce Data Exposure

Return only essential fields and implement field-level access controls

05

Validate Input

Sanitize and validate all request parameters to prevent injection attacks

Recommendation Details

Authentication Layer

- JWT or OAuth 2.0 implementation
- Token expiration and refresh mechanisms
- HTTPS with TLS 1.2+ encryption

Authorization Controls

- Role-Based Access Control (RBAC)
- Attribute-Based Access Control (ABAC)
- Least-privilege principle enforcement

Rate Limiting Strategy

- 100 requests per minute per user
- Sliding window algorithm
- Automatic account lockout after threshold

Data Minimization

- Remove sensitive fields from responses
- Implement field selection (GraphQL)
- Anonymize data where appropriate

Implementation Roadmap

1

Week 1-2

Deploy authentication framework and API gateway

2

Week 3-4

Implement authorization logic and permission checks

3

Week 5-6

Configure rate limiting and request throttling

4

Week 7-8

Test, audit, and document security measures

Estimated timeline assumes existing API infrastructure. Add 2-3 weeks if building from scratch.

Next Steps

1

Conduct Security Audit

Review all endpoints for authentication and authorization gaps

2

Prioritize Critical Endpoints

Focus on /users, /accounts, and financial data first

3

Monitor and Test

Deploy monitoring tools and conduct penetration testing

4

Train Development Team

Establish secure coding practices and API security guidelines

Immediate Action: Disable or protect vulnerable endpoints until security controls are implemented. Contact security team to schedule vulnerability assessment.